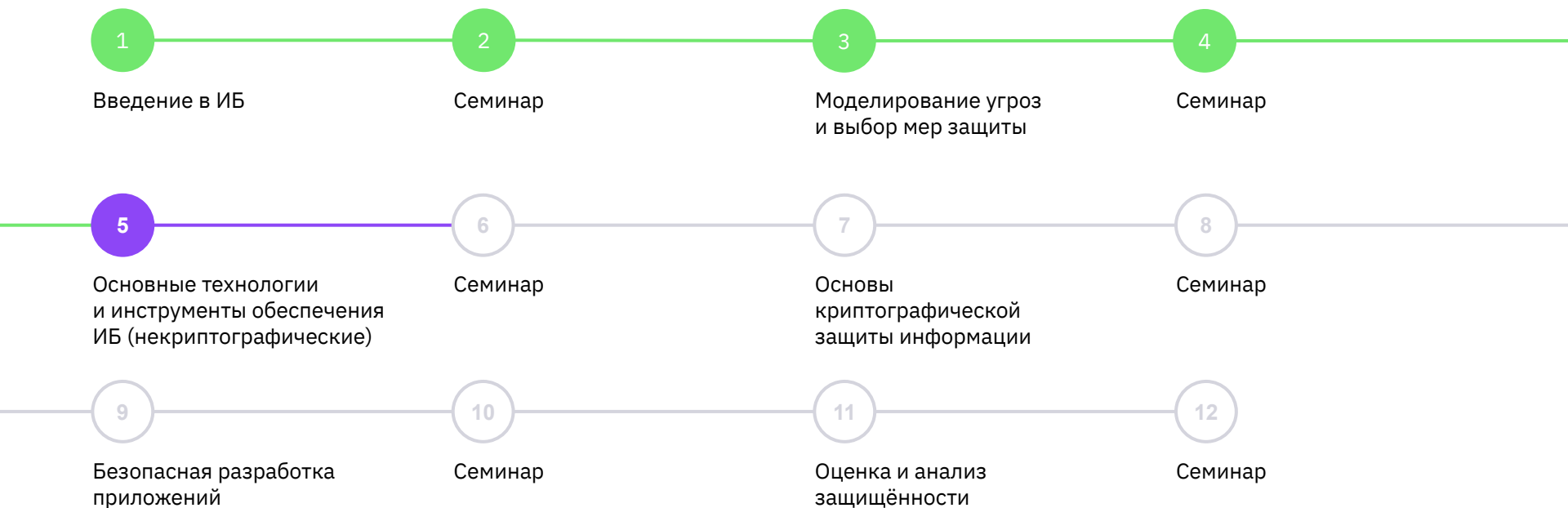


Основы информационной безопасности

Урок 3. Основные технологии
и инструменты обеспечения ИБ (некриптографические)



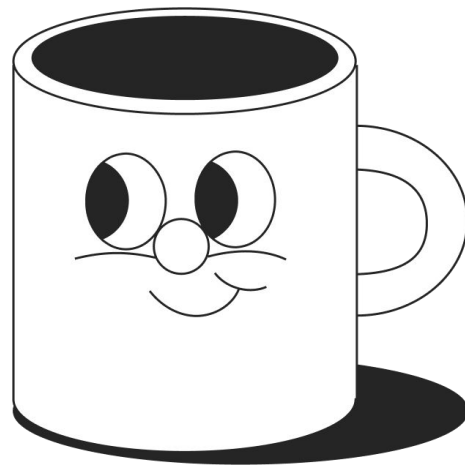
План курса





Что будет на уроке сегодня

- 📌 эволюция технологий и инструментов обеспечения ИБ;
- 📌 классы средств защиты информации;
- 📌 система сертификации средств защиты информации;
- 📌 встроенные и наложенные средства защиты информации;
- 📌 хостовые и сетевые средства защиты информации;
- 📌 средства управления ИБ;
- 📌 интеграции и экосистемы средств защиты информации.



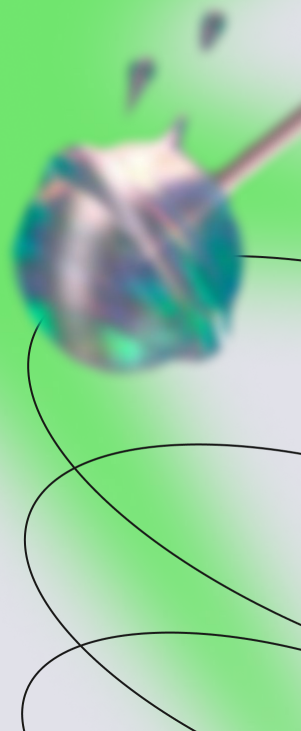


Ключевые понятия

-  **Средство защиты информации:** техническое, программное, программно-техническое средство, вещество и/или материал, предназначенные или используемые для защиты информации.
-  **Техническое средство обеспечения информационной безопасности:** оборудование, используемое для обеспечения информационной безопасности организации некриптографическими методами.
-  **Криптографическое средство защиты информации:** средство защиты информации, реализующее алгоритмы криптографического преобразования информации.
-  **Сертификация на соответствие требованиям по безопасности информации:** форма оценки соответствия требованиям по безопасности информации, установленным нормативными правовыми актами ФСТЭК России, а также техническими условиями, техническим заданием, заданием по безопасности, согласованными заявителями на сертификацию с ФСТЭК России (требования по безопасности информации).

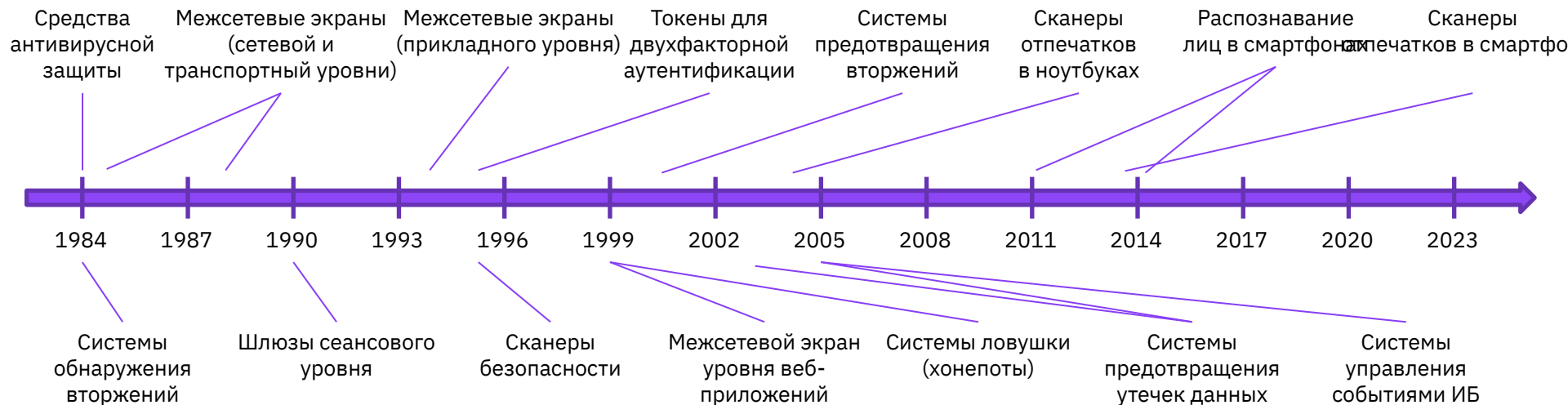


Эволюция технологий и инструментов обеспечения ИБ





История развития средств защиты информации



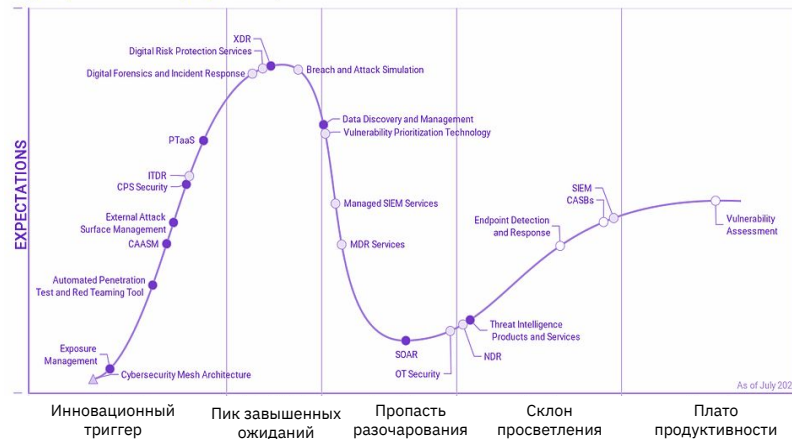


Gartner Hype Cycle

Hype Cycle for Data Security, 2022

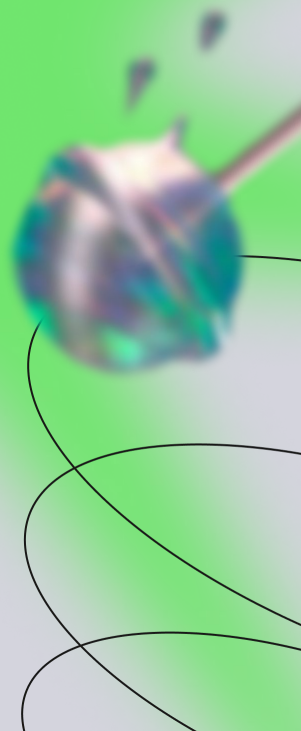
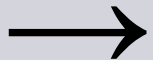


Hype Cycle for Security Operations, 2022





Классы средств защиты информации





Классы средств защиты информации (тех. средств обеспечения ИБ)

По области применения/инсталляции:

-  Хостовые.
-  Сетевые.

По используемым механизмам:

-  Некриптографические (СрЗИ).
-  Криптографические (СКЗИ).

По изначальной принадлежности к системе:

-  Встроенные.
-  Наложённые.

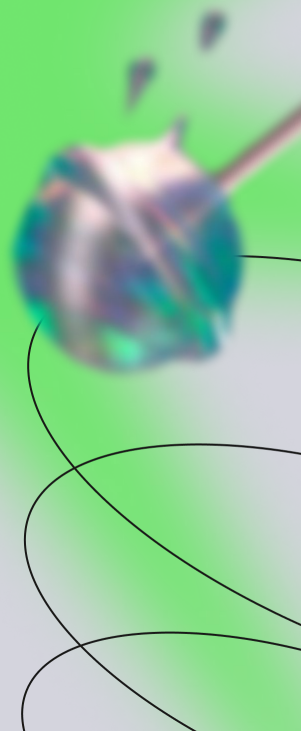
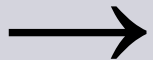
По возможностям противодействия атакующему:

-  Активные.
-  Пассивные.
-  Отвлекающие.

-  Средства контроля (анализа) защищённости.
-  Средства управления (оркестрации).



Система сертификации средств защиты информации





Участники процесса сертификации

Федеральный орган по сертификации (ФСТЭК России):



- 📌 Организует проведение сертификации (система сертификации РОСС RU.01).
- 📌 Разрабатывает и устанавливает требования по безопасности информации.
- 📌 Выпускает сертификаты соответствия.
- 📌 Ведёт государственный реестр сертифицированных СрЗИ: <https://reestr.fstec.ru/reg3>.

Изготовители СрЗИ*

Заявители (организации-изготовители или организации, планирующие применять СрЗИ)

Организации — испытательные лаборатории:

- 📌 Проводят сертификационные испытания.
- 📌 Оформляют технические заключения и протоколы.

Организации — органы по сертификации:

- 📌 Оценивают материалы сертификационных испытаний.
- 📌 Оформляют экспертное заключение о возможности/невозможности выдачи сертификата соответствия.

* Имеют лицензию ФСТЭК России на разработку и производство средств защиты конфиденциальной информации



Порядок проведения сертификации

-  Подача заявки на сертификацию в ФСТЭК России.
-  Принятие ФСТЭК России решения о проведении сертификации СрЗИ.
-  Сертификационные испытания СрЗИ в испытательной лаборатории.
-  Оформление органом по сертификации экспертного заключения по результатам сертификации СрЗИ и проекта сертификата соответствия.
-  Выдача (отказ в выдаче) ФСТЭК России сертификата соответствия.
-  Предоставление дубликата сертификата соответствия (при необходимости).
-  Маркирование СрЗИ.
-  Внесение изменений в сертифицированное СрЗИ (при необходимости).
-  Переоформление сертификата соответствия (при необходимости).
-  Продление срока действия сертификата соответствия.
-  Приостановление действия сертификата соответствия.
-  Прекращение действия сертификата соответствия.

Варианты (схемы) сертификации

- 📌 Для единичного образца СрЗИ – проведение испытаний образца и проверки организации его технической поддержки*.
- 📌 Для партии СрЗИ – проведение испытаний выборки образцов и проверки организации его технической поддержки*.
- 📌 Для серийного производства СрЗИ – проведение испытаний выборки образцов и проверки организации его производства и технической поддержки**.
- 📌 Срок действия сертификата соответствия не может превышать 5 лет для схемы серийного производства СрЗИ.
- 📌 Срок действия сертификата соответствия не устанавливается для единичного образца или партии СрЗИ (бессрочный).

* Организуется заявителем, планирующим применять СрЗИ, в случае, если отсутствуют идентичные серийные аналоги

** Организуется заявителем, осуществляющим разработку и/или производство СрЗИ

**СИСТЕМА СЕРТИФИКАЦИИ
СРЕДСТВ ЗАЩИТЫ ИНФОРМАЦИИ**

ПО ТРЕБОВАНИЯМ БЕЗОПАСНОСТИ ИНФОРМАЦИИ
№ РОСС RU.0001.01BIO00

СЕРТИФИКАТ СООТВЕТСТВИЯ
№ 3905

Внесен в государственный реестр системы сертификации
средств защиты информации по требованиям безопасности информации
26 марта 2018 г.

Выдан: 26 марта 2018 г.
Действителен до: 26 марта 2021 г.
Срок действия процедуры до: 26 марта 2026 г.

Настоящий сертификат удостоверяет, что изделие «Универсальный шлюз безопасности «UserGate»», разработанное и производимое ООО «Юзергейт», является средством обнаружения вторжений и межсетевым экраном, соответствует требованиям по безопасности информации, установленным в документах «Требования по безопасности информации, устанавливающие уровни доверия к средствам технической защиты информации и средствам обеспечения безопасности информационных технологий» (ФСТЭК России, 2020) - по 4 уровню доверия, «Требования к межсетевым экранам» (ФСТЭК России, 2016), «Профиль защиты межсетевых экранов типа А четвертого класса защиты, ИТМЭ.А4.ПЗ» (ФСТЭК России, 2016), «Профиль защиты межсетевых экранов типа В четвертого класса защиты, ИТМЭ.В4.ПЗ» (ФСТЭК России, 2016), «Профиль защиты межсетевых экранов типа Д четвертого класса защиты, ИТМЭ.Д4.ПЗ» (ФСТЭК России, 2016), «Требования к системам обнаружения вторжений» (ФСТЭК России, 2011), «Профиль защиты систем обнаружения вторжений уровня сети четвертого класса защиты, ИТСОВ.С4.ПЗ» (ФСТЭК России, 2012) при выполнении указанных по эксплуатации, приведенных в формуляре РГТФ.460000.001 I.B.

Сертификат выдан на основании технического заключения от 07.02.2018, оформленного по результатам сертификационных испытаний испытательной лабораторией АО «НИИО «Экспозит» (аттестат аккредитации от 18.04.2017 № СИИ RU.0001.01BIO0.0218), экспертного заключения от 15.02.2018, оформленного органом по сертификации ФАУ «НИИИ ПТЗИ ФСТЭК России» (аттестат аккредитации от 05.05.2016 № СИИ RU.0001.01BIO0.A002), и технических заключений от 24.04.2020 и 03.02.2021, оформленных испытательной лабораторией АО «НИО «Экспозит».

Заявитель: ООО «Юзергейт»
Адрес: 630090, г. Новосибирск, ул. Нималева, д. 11, оф. 602
Телефон: (383) 286-2913

ЗАМЕСТИТЕЛЬ ДИРЕКТОРА ФСТЭК РОССИИ

В.Лютиков

Примечание: сертифицированное изделие, указанной в настоящем сертификате соответствия, не является (объекты авторского права) разрешением для внесения сведений о ней в государственный реестр средств защиты информации по требованиям безопасности информации

срок
действия

требования

испытательная
лаборатория
орган по
сертификации
заявитель

ФСТЭК России



Реестр сертифицированных средств



Реестры ФСТЭК России

ФЕДЕРАЛЬНАЯ СЛУЖБА ПО ТЕХНИЧЕСКОМУ И ЭКСПОРТНОМУ КОНТРОЛЮ






Государственный реестр сертифицированных средств защиты информации

 Обновлено: 14.07.2023 15:30
  Просмотров: 129843

ODS

Государственный реестр ССЗИ

Размер: 233 КБ

Скачивания: 5951

CSV

Государственный реестр ССЗИ

Размер: 1 МБ

Скачивания: 2710

Искать в таблице

Отображать 10 записей

№ сертификата	Дата внесения в реестр	Срок действия сертификата	Наименование средства (шифр)	Наименования документов, требованиям которых соответствует средство	Схема сертификации	Испытательная лаборатория
Поиск	Поиск	Поиск	Поиск	Поиск	Поиск	Поиск
4691	12.07.2023	12.07.2028	СУБД «Квант-гибрид 1.5.1»	Соответствует требованиям документов: Требования доверия(4), ТУ	серия	ООО «ЦЕИ»
4690	11.07.2023	Бессрочно	программное обеспечение «Приложение «Управление процессами рисками»	Соответствует требованиям документов: Требования доверия(6), ТУ	1	АО «ДОКУМЕНТАЛЬНЫЕ СИСТЕМЫ»
4689	07.07.2023	Бессрочно	прикладное программное обеспечение Технологического портала Департамента информационных технологий города Москвы	Соответствует требованиям документов: Требования доверия(6), ТУ	1	АО «ДОКУМЕНТАЛЬНЫЕ СИСТЕМЫ»

	A	B	C	D	E	F	G
	№ сертификата	Дата внесения в реестр	Срок действия сертификата	Наименование средства (шифр)	Наименования документов, требованиям которых соответствует средство	Схема сертификации	Испытательная лаборатория
1	17/1	26.07.2002	01.08.2020	фильтр сетевой помехоподавляющий ФСПК-100(200)-0,22/0,38-91 УХЛ4	Соответствует требованиям документов: Требования к ПСЗ ПЭМИН-2015	серия	ЦКБ И ФГУП
2	21/2	25.06.2013	25.06.2019	программный комплекс защиты информации от НСД «Страж 1.1»	Соответствует требованиям документов: РД СВТ(2)	1	АО «Информационные технологии академического центра»
3	27/1	24.05.2005	24.05.2020	устройство «Корунд»	Соответствует требованиям документов: ТУ	серия	ЗАО «НПП
4	32/1	20.04.1996	17.04.2021	система защиты информации от несанкционированного доступа «Снег 2.0»	Соответствует требованиям документов: РД СВТ(2)	1	ФГУП «СКЛ
5	32/2	20.04.1996	17.04.2021	система защиты информации от несанкционированного доступа «Снег 2.0»	Соответствует требованиям документов: РД СВТ(2)	1	ФГУП «СКЛ
6	41/5/10	30.03.2011	30.03.2020	система защиты «Гром-ЗИ-4»	Соответствует требованиям документов: РД САЗ ПЭМИН-87	1	ЗАО «НПП
7	41/5/17	18.04.2013	18.04.2019	система защиты «Гром-ЗИ-4»	Соответствует требованиям документов: РД САЗ ПЭМИН-87	1	АО «ФНПЦ
8	41/6/5	09.03.2011	09.03.2020	система защиты «Гром-ЗИ-4А»	Соответствует требованиям документов: РД САЗ ПЭМИН-87, ТУ	1	ООО по заказу «Секрет-С
9	41/6/47	30.10.2012	30.10.2018	система защиты «Гром-ЗИ-4А»	Соответствует требованиям документов: РД САЗ ПЭМИН-87, ТУ	1	АО «ФНПЦ
10							



Общие критерии (Common Criteria)

-  Руководящие документы Гостехкомиссия России (теперь ФСТЭК России) «Безопасность информационных технологий. Критерии оценки безопасности информационных технологий» (2003 г.), 3 части.
-  ГОСТ Р ИСО/МЭК 15408 «Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий» (2012 – 2013 гг.), 3 части.
-  Требования по безопасности информации, устанавливающие уровни доверия к средствам технической защиты информации и средствам обеспечения безопасности информационных технологий, утв. приказом ФСТЭК России от 02.06.2020 N 76.
-  ISO/IEC 15408 «Information security, cybersecurity and privacy protection — Evaluation criteria for IT security» (1999-2022 гг.), 5 частей.



Общие критерии (Common Criteria)

Средство соответствует уровню доверия, если оно удовлетворяет требованиям:

-  к разработке и производству средства;
-  проведению испытаний средства;
-  поддержке безопасности средства;

-  для каждого типа СрЗИ ФСТЭК России утверждается нормативно-правовой акт «Требования по безопасности информации» (с классами средств);
-  для каждого класса и каждого типа СрЗИ ФСТЭК России утверждаются «Профили защиты»;
-  для каждого конкретного СрЗИ заявителем разрабатывается «Задание по безопасности».

6 уровень доверия (СрЗИ 6 класса)

- ЗОКИИ: 3 категория
- ГИС: 3 класс защищённости
- ИСПДн: 3 и 4 уровни защищённости ПДн

5 уровень доверия (СрЗИ 5 класса)

- ЗОКИИ: 2 категория
- ГИС: 2 класс защищённости
- ИСПДн: 2 уровень защищённости ПДн

4 уровень доверия (СрЗИ 4 класса)

- ЗОКИИ: 1 категория
- ГИС: 1 класс защищённости
- ИСПДн: 1 уровень защищённости ПДн



Требования по безопасности информации

- ✚ к системам обнаружения вторжений;
 - ✚ средствам антивирусной защиты;
 - ✚ средствам доверенной загрузки;
 - ✚ средствам контроля съемных машинных носителей информации;
 - ✚ межсетевым экранам;
 - ✚ операционным системам;
 - ✚ средствам обеспечения безопасной дистанционной работы в системах;
 - ✚ средствам контейнеризации;
 - ✚ средствам виртуализации
- или просто уровень доверия и технические условия*.

* Если нет явных требований для данного класса СрЗИ

Профили защиты

Методический документ от 12 сентября 2016 г.
Профили защиты межсетевых экранов

PDF	Профиль защиты межсетевых экранов типа А четвертого класса защиты	Размер: 877.70 КБ	Скачивания: 425
ODT	Профиль защиты межсетевых экранов типа А четвертого класса защиты	Размер: 227.44 КБ	Скачивания: 130
PDF	Профиль защиты межсетевых экранов типа А пятого класса защиты	Размер: 821.41 КБ	Скачивания: 97
ODT	Профиль защиты межсетевых экранов типа А пятого класса защиты	Размер: 169.15 КБ	Скачивания: 74
PDF	Профиль защиты межсетевых экранов типа А шестого класса защиты	Размер: 627.24 КБ	Скачивания: 111
ODT	Профиль защиты межсетевых экранов типа А шестого класса защиты	Размер: 123.61 КБ	Скачивания: 112
PDF	Профиль защиты межсетевых экранов типа Б четвертого класса защиты	Размер: 868.21 КБ	Скачивания: 173
ODT	Профиль защиты межсетевых экранов типа Б четвертого класса защиты	Размер: 218.38 КБ	Скачивания: 75
PDF	Профиль защиты межсетевых экранов типа Б пятого класса защиты	Размер: 824.09 КБ	Скачивания: 78
ODT	Профиль защиты межсетевых экранов типа Б пятого класса защиты	Размер: 169.40 КБ	Скачивания: 79
PDF	Профиль защиты межсетевых экранов типа Б шестого класса защиты	Размер: 630.42 КБ	Скачивания: 144
ODT	Профиль защиты межсетевых экранов типа Б шестого класса защиты	Размер: 122.68 КБ	Скачивания: 77
PDF	Профиль защиты межсетевых экранов типа В четвертого класса защиты	Размер: 819.03 КБ	Скачивания: 111
ODT	Профиль защиты межсетевых экранов типа В четвертого класса защиты	Размер: 195.70 КБ	Скачивания: 67
PDF	Профиль защиты межсетевых экранов типа В пятого класса защиты	Размер: 740.32 КБ	Скачивания: 72
ODT	Профиль защиты межсетевых экранов типа В пятого класса защиты	Размер: 164.81 КБ	Скачивания: 51
PDF	Профиль защиты межсетевых экранов типа В шестого класса защиты	Размер: 626.67 КБ	Скачивания: 89
ODT	Профиль защиты межсетевых экранов типа В шестого класса защиты	Размер: 122.03 КБ	Скачивания: 60
PDF	Профиль защиты межсетевых экранов типа Г четвертого класса защиты	Размер: 863.90 КБ	Скачивания: 136
ODT	Профиль защиты межсетевых экранов типа Г четвертого класса защиты	Размер: 215.68 КБ	Скачивания: 65
PDF	Профиль защиты межсетевых экранов типа Г пятого класса защиты	Размер: 874.38 КБ	Скачивания: 153
ODT	Профиль защиты межсетевых экранов типа Г пятого класса защиты	Размер: 181.07 КБ	Скачивания: 69
PDF	Профиль защиты межсетевых экранов типа Г шестого класса защиты	Размер: 665.27 КБ	Скачивания: 74
ODT	Профиль защиты межсетевых экранов типа Г шестого класса защиты	Размер: 133.75 КБ	Скачивания: 66
PDF	Профиль защиты межсетевых экранов типа Д четвертого класса защиты	Размер: 805.70 КБ	Скачивания: 128
ODT	Профиль защиты межсетевых экранов типа Д четвертого класса защиты	Размер: 194.92 КБ	Скачивания: 73
PDF	Профиль защиты межсетевых экранов типа Д пятого класса защиты	Размер: 844.77 КБ	Скачивания: 71
ODT	Профиль защиты межсетевых экранов типа Д пятого класса защиты	Размер: 178.25 КБ	Скачивания: 66
PDF	Профиль защиты межсетевых экранов типа Д шестого класса защиты	Размер: 641.19 КБ	Скачивания: 114
ODT	Профиль защиты межсетевых экранов типа Д шестого класса защиты	Размер: 124.16 КБ	Скачивания: 107

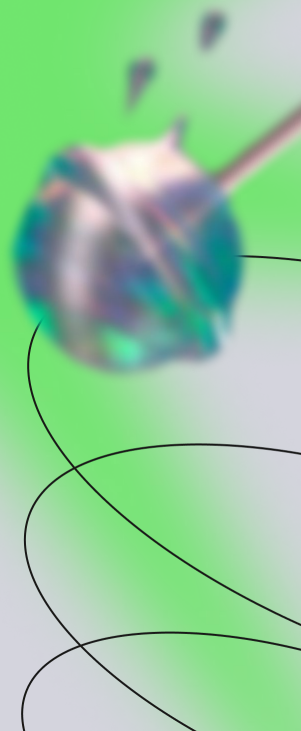
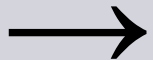


Выводы по модулю

-  изначально учитывайте необходимость (отсутствие необходимости) сертификации по требованиям безопасности информации разрабатываемого ПО (например, применение в составе ГИС);
-  проверяйте наличие готовых «Требований по безопасности информации» и «Профилей защиты» к соответствующим классам (типам) СрЗИ, учитывайте их положения при разработке;
-  помните, что в процессе сертификации участвуют несколько сторон, процесс стоит денег и может занимать по времени примерно полгода;
-  внесение изменений в ПО потребует проведения дополнительных испытаний, т.е. сертификация не является разовым мероприятием.



Встроенные и наложенные средства защиты информации





Ключевые встроенные средства (механизмы) защиты информации

Управление доступом (*access management*)

-  **Идентификация:** действия по присвоению субъектам и объектам доступа идентификаторов и/или по сравнению предъявляемого идентификатора с перечнем присвоенных идентификаторов.
-  **Аутентификация:** действия по проверке подлинности субъекта доступа и/или объекта доступа, а также по проверке принадлежности субъекту доступа и/или объекту доступа, предъявленного идентификатора доступа и аутентификационной информации.
-  **Авторизация:** предоставление субъекту доступа прав доступа, а также предоставление доступа в соответствии с установленными правилами управления доступом.
-  **Регистрация (учёт) событий безопасности:** процесс автоматического (автоматизированного) занесения в электронный журнал регистрации событий безопасности записи о событии безопасности.

*Authentication, authorization, and accounting
(AAA)*

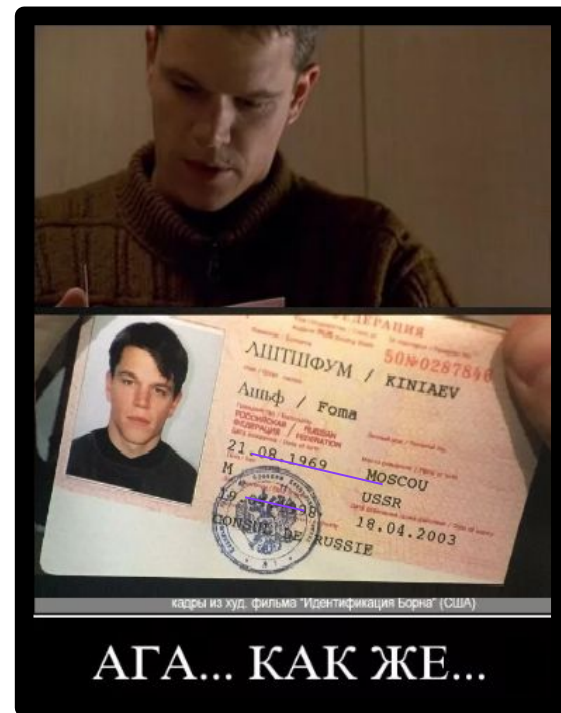
Идентификация

Идентификация пользователя:

- 📌 Первичная: присвоение субъекту (объекту) доступа идентификатора (регистрация).
- 📌 Вторичная: проверка при доступе существования предъявленного субъектом (объектом) идентификатора.

Уникальный идентификатор пользователя:

- 📌 User name.
- 📌 Login ID.
- 📌 Personal Identification Number (PIN).
- 📌 Адрес электронной почты (при регистрации на внеш. ресурсах).
- 📌 Устройства идентификации.



Аутентификация

Факторы, применяемые в процессе аутентификации:

Факторы знания (something you know):

-  Пароль (password).
-  Ответ на «секретный» вопрос.
-  Фактор владения (something you have): 
-  Токен (token).
-  «Таблетка» (touch memory, iButton).
-  Биометрический фактор (something you are) или поведение (something you do):
-  отпечаток пальца;
-  сетчатка или радужная оболочка глаза;
-  геометрия лица.



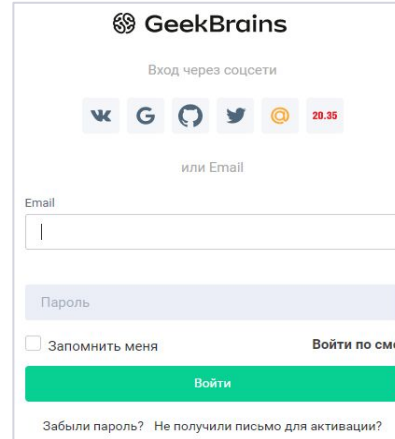
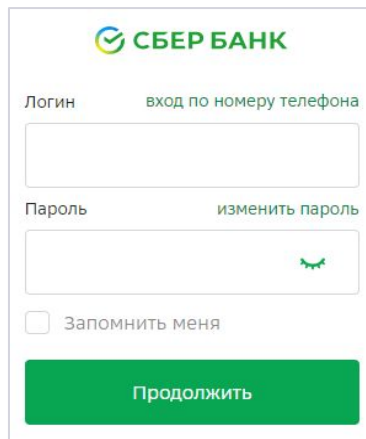
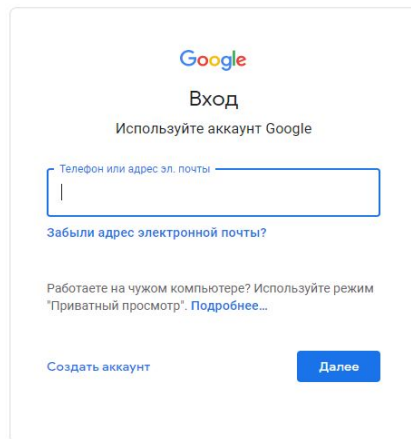
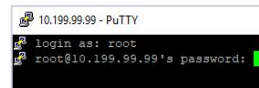
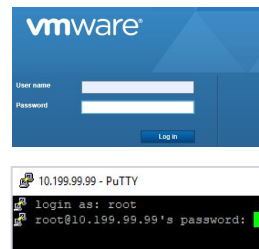
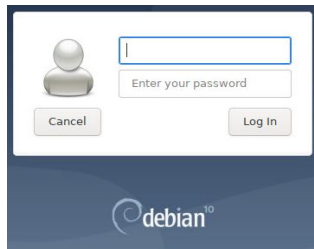
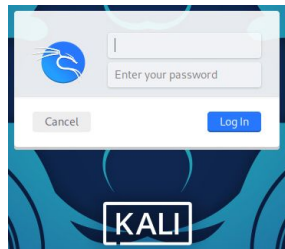
По количеству используемых факторов:

-  Однофакторная аутентификация.
-  Многофакторная аутентификация (чаще всего двухфакторная: пароль + токен)*.

* Технология единой «сквозной» аутентификации: single sign-on (SSO)



Идентификация и аутентификация





**«Как ни плохи пароли, люди находят способ сделать их ещё хуже.
Если вы попросите их выбрать пароль, он будет паршивый.
Если вы принудите их выбрать хороший пароль,
они напишут его на карточке и прикрепят к монитору.
Если вы попросите поменять его, они сменят его на пароль,
которым пользовались месяц назад»**

Писатель, эксперт по ИБ, Брюс Шнайер, 2003 г.





Пароли

Наиболее популярные пароли:

- password;
- 123456;
- 123456789;
- guest;
- qwerty;
- 111111.

Длина пароля: 8+символов

Сложность пароля:

- требования к составу (Aa1@);
- мнемонические пароли.

Смена пароля:

- периодическая;
- при подозрении на компрометацию.

The screenshot displays the Kaspersky Password Checker interface with four password examples and their security status:

- 123456:** Bad password. Reasons: Poor quality, repeating symbol sequences, and it's a common password found in 37615083 leaks.
- Pa\$\$w0rd:** Bad password. Reasons: Poor quality, common word, and it's a common password found in 13981 leaks.
- PoluYH43@!:** Bad password. Reasons: Poor quality, using "keyboard" sequences, and it's a common password found in leaks.
- RjfdY6323(Tv:** Good password. Reasons: Good quality, resistant to brute force, and not found in leaks.

Below the passwords, a message states: "Для подбора вашего пароля потребуется... 327 веков" (To select your password, it will take... 327 centuries).

* Kaspersky Lab.:
<https://password.kaspersky.com/ru/>



Утечка паролей

2

IP

Проверка почты на взлом

В данном сервисе вы сможете найти свой email или пароль в базах данных, которые были украдены.

Все запросы полностью конфиденциальны. Это означает, что мы не храним логи искоемых email или паролей и гарантируем 100% безопасность введенных данных.

Для безопасного поиска паролей мы используем модель "[k-anonymity](#)". На стороне браузера мы вычисляем hash и берём его небольшой участок, который и используем для поиска в базе.

Это позволяет не отправлять ваш пароль куда либо, и полностью гарантирует его сохранность.

Данные предоставлены сервисом [leakcheck.io](#)

Пароль или email:

Найти

Сервис	Пароль	Дата утечки
CDEK		2022-04
Collection 1	1983****	2019-01
-	9466****	-

Home

Notify me

Domain search

Who's been pwned

Passwords

API

About

Donate

'--have i been pwned?

Check if your email or phone is in a data breach

pwned?

Oh no — pwned!

Pwned in 4 data breaches and found no pastes ([subscribe to search sensitive breaches](#))

Home

Notify me

Domain search

Who's been pwned

Passwords

API

About

Donate

'--have i been pwned?

Check if your email or phone is in a data breach

pwned?

Good news — no pwnage found!

No breached accounts and no pastes ([subscribe to search sensitive breaches](#))

* 2ip: <https://2ip.ru/pwned/>. Troy Hunt: <https://haveibeenpwned.com/>



Популярные парольные атаки (способ реализации угроз)

 Предусмотренная отдельная тактика MITRE ATT&CK® «Credential Access»

Варианты популярных парольных атак:

-  угадать пароль (password guessing);
-  «распылить» пароль (password spraying).

Взломать пароль через его хэш (password cracking):

-  словарные атаки;
-  гибридные атаки;
-  brute-force атаки.

Перехватить пароль, передаваемый в открытом виде.

Получить доступ к паролю, хранящемуся в открытом виде.

Credential Access 17 techniques	
Adversary-in-the-Middle (3)	II
Brute Force (4)	II
Credentials from Password Stores (5)	II
Exploitation for Credential Access	
Forced Authentication	
Forge Web Credentials (2)	II
Input Capture (4)	II
Modify Authentication Process (3)	II
Multi-Factor Authentication Interception	
Multi-Factor Authentication Request Generation	
Network Sniffing	
OS Credential Dumping (8)	II
Steal Application Access Token	
Steal or Forge Authentication Certificates	
Steal or Forge Kerberos Tickets (4)	II
Steal Web Session Cookie	
Unsecured Credentials (8)	II



Современные протоколы аутентификация

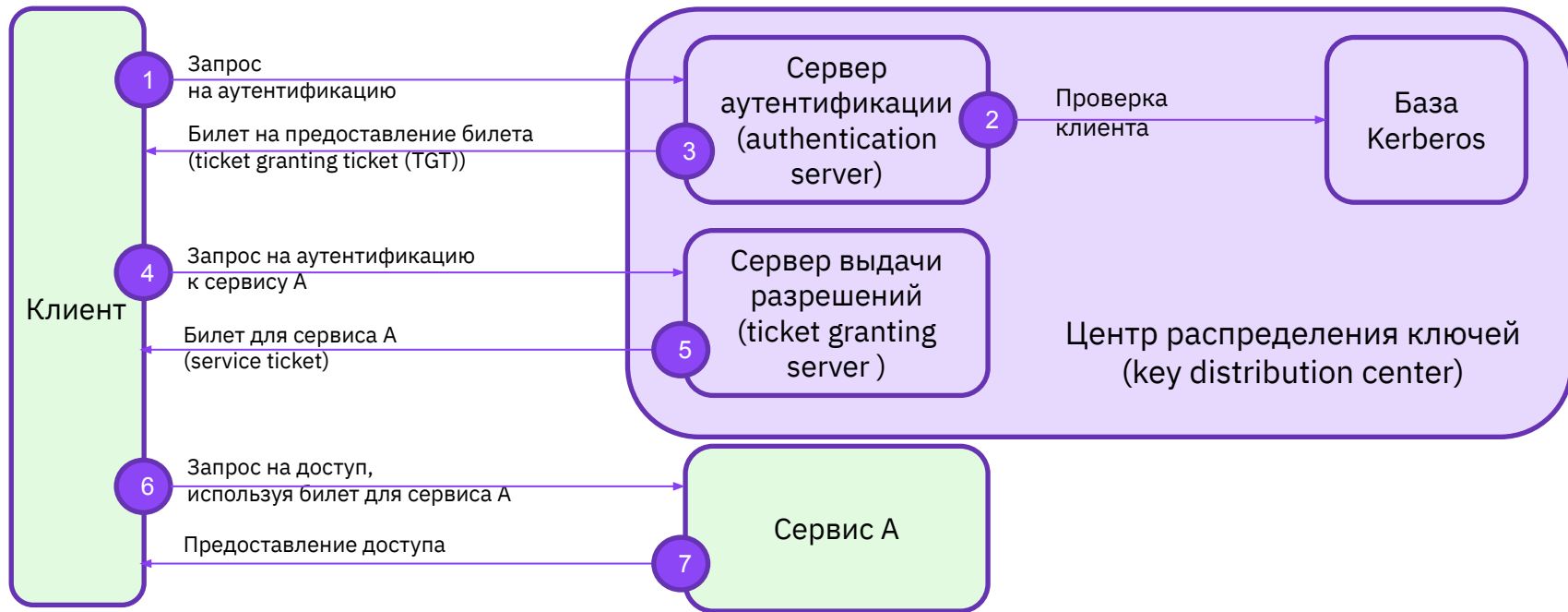
-  Password Authentication Protocol (PAP).
-  Challenge Handshake Authentication Protocol (CHAP).
-  Lightweight Directory Access Protocol (LDAP).
-  Kerberos.
-  Security Assertion Markup Language (SAML).
-  Transport Level Security (TLS).
-  OAuth и OpenID Connect (OIDC).

API Authentication Methods:

-  Basic HTTP Authentication.
-  API Keys.
-  OAuth 2.0.



Kerberos





Авторизация*

Мандатное разграничение прав доступа (Mandatory Access Control (MAC)):

-  Нет чтения вверх (no read up).
-  Нет записи вниз (no write down).

Дискреционное разграничение прав доступа (Discretionary Access Control (DAC))**:

-  Матрица доступа (access control matrix).
-  Списки доступа (access control list).

Ролевое разграничение прав доступа (Role-Based Access Control (RBAC))**

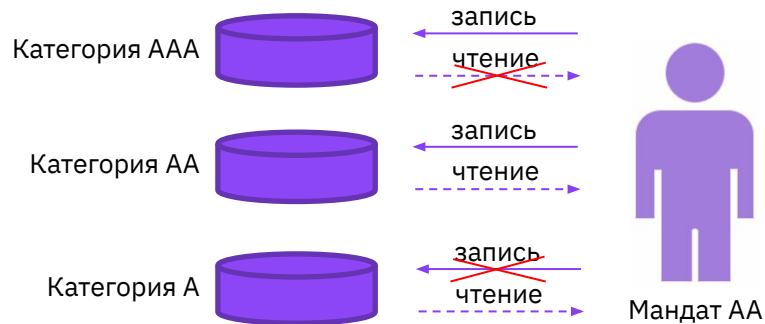
* Принцип «**Principle of least privilege**»: предоставление минимально возможного уровня привилегий / разрешений

** Используется в подавляющем числе ПО

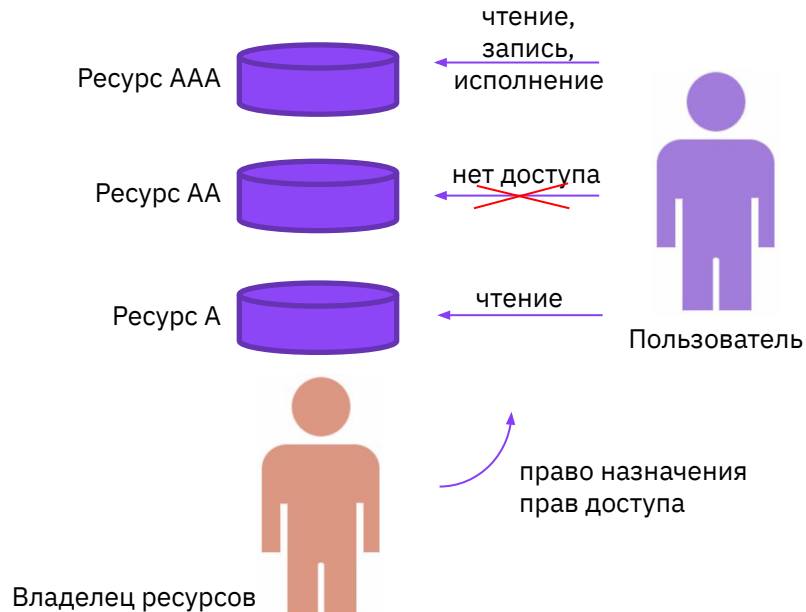


Авторизация

 Мандатное разграничение прав доступа (MAC)

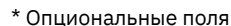


 Дискреционное разграничение доступа (DAC)



Ведение журналов аудита событий (log-файлов) / Аудит событий безопасности (audit)

- дата и время регистрации события (метка времени);
- идентификатор события;
- содержательная часть события;
- категория события*;
- уровень важности (критичности) события*.





Популярные категории событий безопасности

- 📌 Управление учётными записями и аутентификаторами (паролями), особенно привилегированными учётными записями.
- 📌 Вход и попытки входа пользователей, особенно удалённого доступа и попытки входа привилегированных пользователей.
- 📌 Управление журналами (записями) регистрации событий, особенно отключение аудита событий или очистка журналов аудита событий.
- 📌 Сбои в работе СрЗИ, особенно отключение СрЗИ или длительное отсутствие связи с системой управления.

 Вход учетной записи
 Управление учетными записями
 Подробное отслеживание
 Доступ к службе каталогов (DS)
 Вход/выход
 Доступ к объектам
 Изменение политики
 Использование привилегий
 Система
 Аудит доступа к глобальным объектам

Syslog Severity	Severity Level
Emergency	Level 0, highest level
Alert	Level 1
Critical	Level 2
Error	Level 3
Warning	Level 4
Notice	Level 5
Informational	Level 6
Debugging	Level 7



Ключевые наложенные средства защиты информации

Средство антивирусной защиты (антивирус):

Обнаружение вредоносного ПО:

- ✚ сигнатурный анализ;
- ✚ эвристический (вероятностный) анализ;
- ✚ поведенческий анализ;
- ✚ удаление вредоносного ПО;
- ✚ обработка инфицированных объектов с целью их восстановления;
- ✚ блокирование определённых операций и/или ПО;
- ✚ обновление баз данных признаков вредоносного ПО;



Сервисы для антивирусного (репутационного) анализа:



<https://www.virustotal.com/>
 **VIRUSTOTAL**



<https://opentip.kaspersky.com/>
 **Kaspersky**
Threat Intelligence Portal



<https://www.abuseipdb.com/>
 **AbuseIPDB**



<https://exchange.xforce.ibmcloud.com/>
 **IBM X-Force Exchange**



Ключевые наложенные средства защиты информации

СрЗИ от несанкционированного доступа (НСД):

-  двухфакторная аутентификация;
-  доверенная загрузка;
-  мандатное разграничение прав доступа;
-  контроль целостности отдельных файлов;
-  расширенный аудит событий безопасности;
-  гарантированное удаление данных (затирание).

Особенности применения наложенных антивирусов и СрЗИ от НСД:

-  совместимость с общесистемным и прикладным ПО;
-  негативное влияние на производительность хоста;
-  доп. квалификация для администрирования.

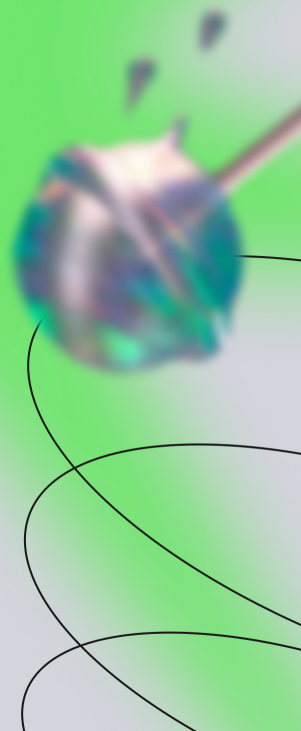
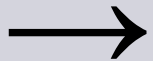


Выводы по модулю

-  Начинайте с использования встроенных средств (механизмов) защиты информации.
-  Идентификация и аутентификация – это первый рубеж в составе любой системы защиты информации.
-  Грамотное разграничение прав доступа (авторизация) в совокупности с принципом минимальных привилегий позволят нейтрализовать большую часть способов реализации угроз.
-  Регистрация событий позволит обнаружить те способы реализации угроз, которые могут быть успешными несмотря на идентификацию, аутентификацию и авторизацию (а такие всегда найдутся).
-  Среди наложенных СрЗИ – решением по умолчанию является антивирус.
-  Целесообразность применения наложенных СрЗИ от НСД должна определяться моделью угроз после предварительного тестирования на совместимость.



Хостовые и сетевые средства защиты информации





Хостовые и сетевые СрЗИ



Персональный межсетевой экран



Межсетевой экран



Host IDS



Network IDS



Хостовые агенты системы предотвращения утечек данных (DLP)



Сетевые сенсоры систем предотвращения утечек данных (DLP)



Endpoint Detection and Response (EDR)



Network Traffic Analysis (NTA)

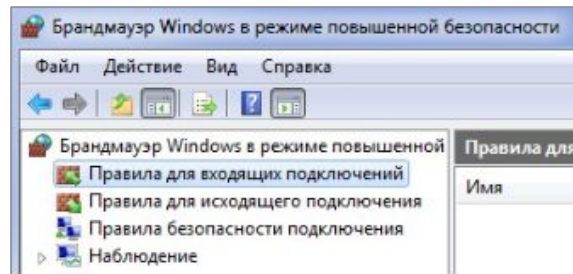
Extended Detection and Response (XDR)



Межсетевой экран

Брандмауэр, Firewall (FW), Unified Threat Management (UTM):

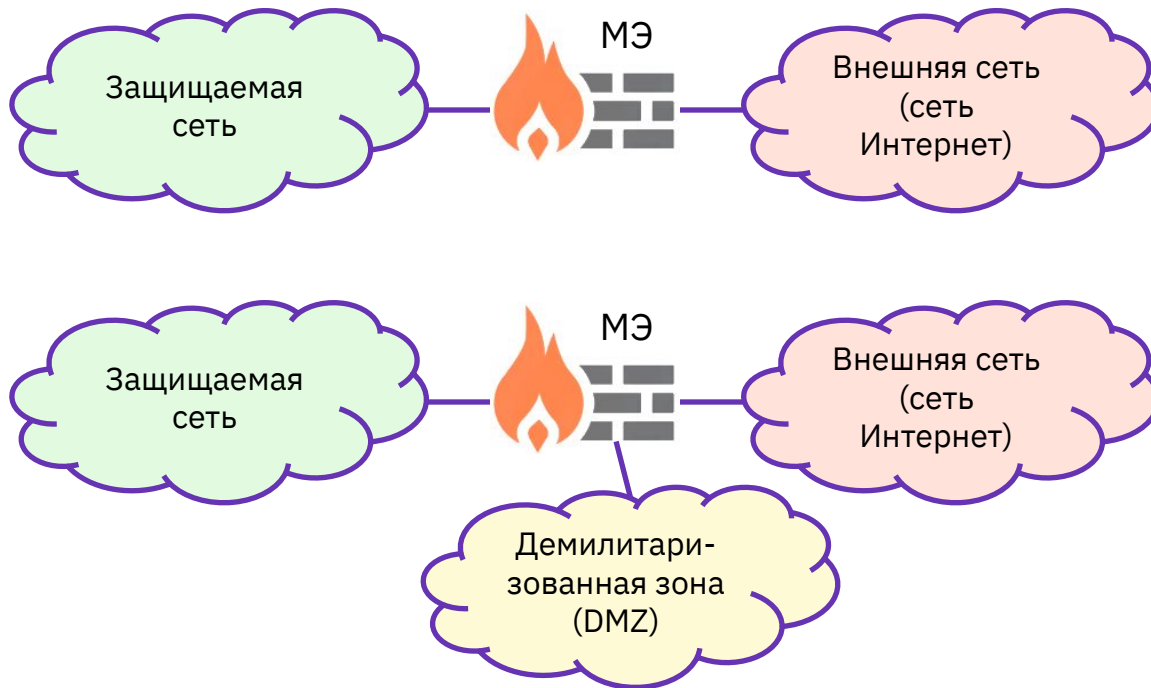
- 📌 пакетная фильтрация;
- 📌 сетевая трансляция адресов;
- 📌 трансляция портов;
- 📌 аутентификация пользователей, клиентов, сессий;
- 📌 управление бюджетами пользователей;
- 📌 виртуальные частные сети;
- 📌 посредник транспортного уровня;
- 📌 посредник прикладного уровня.



```
linux@a ~$ iptables-translate -A INPUT -s 192.168.2.1 -j DROP
nft add rule ip filter INPUT ip saddr 192.168.2.1 counter drop
```

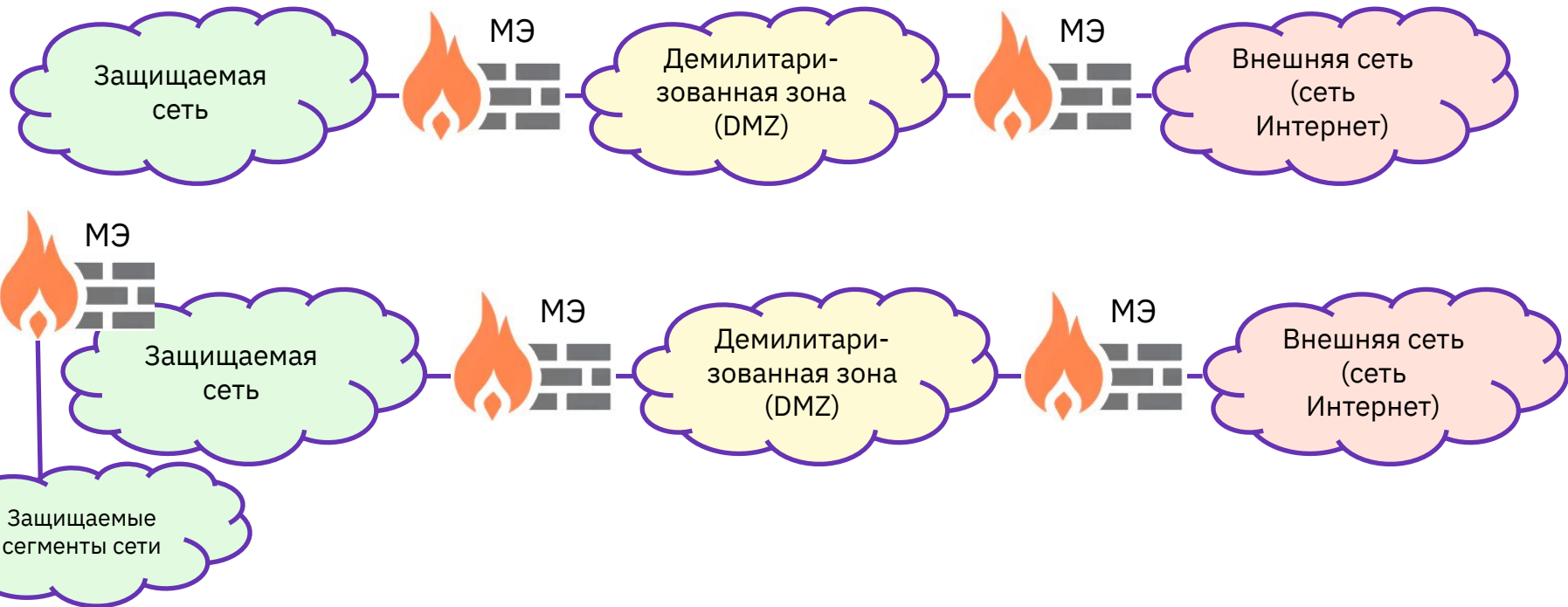


Популярные схемы размещения межсетевых экранов





Популярные схемы размещения межсетевых экранов





Системы предотвращения вторжений

Система предотвращения вторжений (Intrusion prevention systems (IPS))

Система обнаружения вторжений (Intrusion Detection Systems (IDS)):



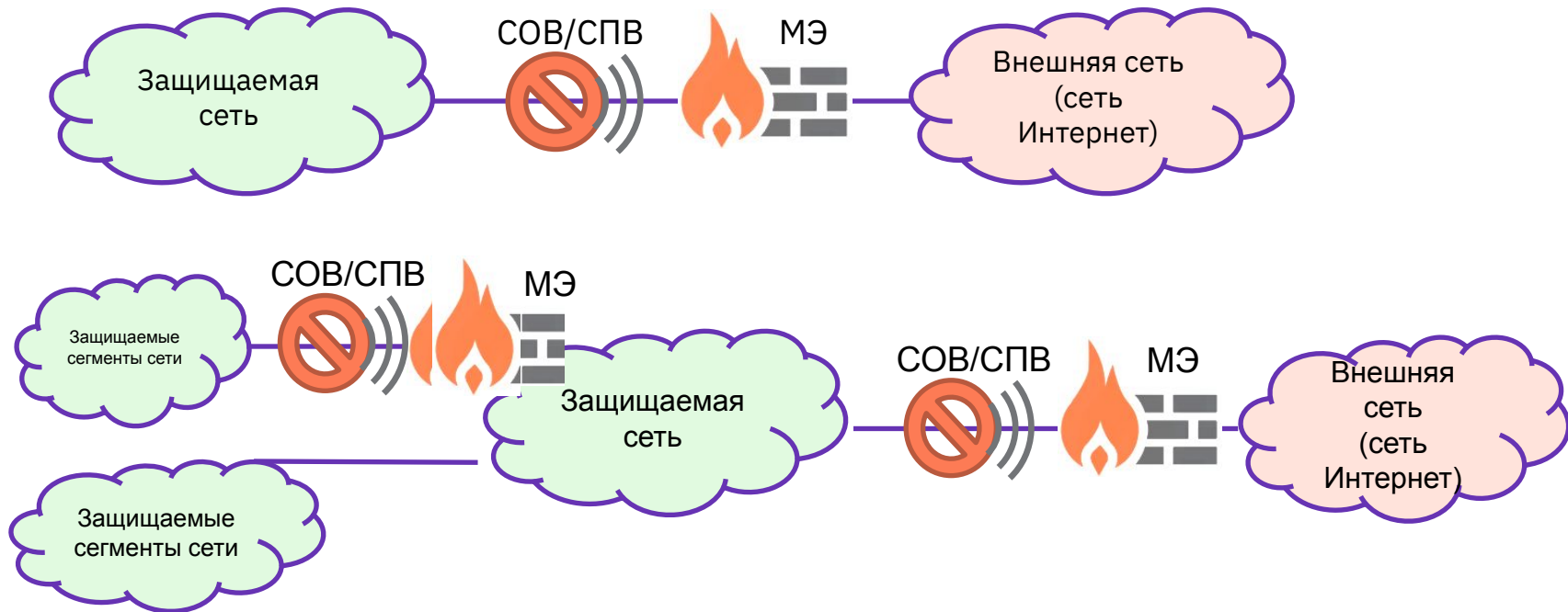
Обнаружение и/или блокирование сетевых атак.



Обновление баз данных признаков сетевых атак.



Популярные схемы системы предотвращения вторжений



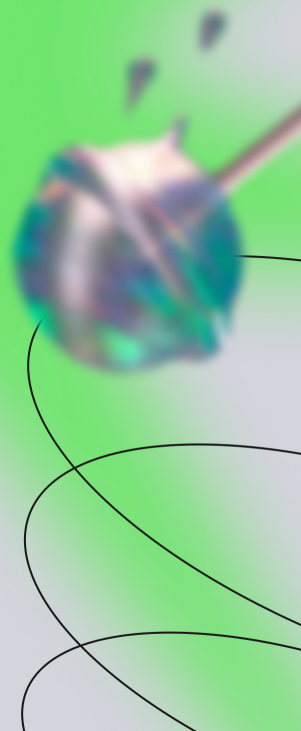
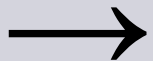


Выводы по модулю

-  Архитектура и схема применения хостовых и/или сетевых СрЗИ определяется конкретными ИТ-условиями и моделью угроз.
-  Грамотное разграничение прав сетевого доступа в совокупности с принципом «всё, что явно не разрешено – запрещено» позволят нейтрализовать большую часть способов реализации угроз.



Средства управления ИБ





Средства управления ИБ

Компонент управления в составе отдельного решения – «Сервер/консоль управления»:

-  локальный ;
-  централизованный (оркестратор).

Системы, предназначенные именно для управления:

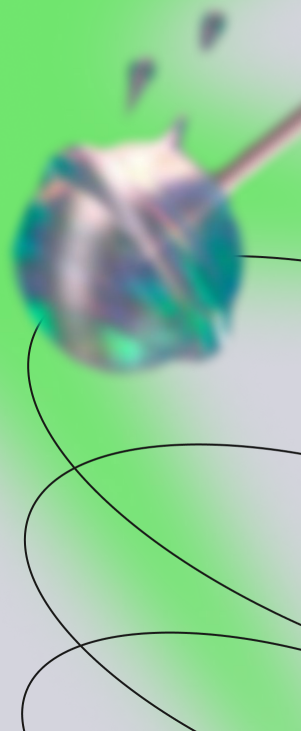
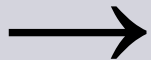
-  данными (Security Governance, Risk Management and Compliance (SGRC));
-  конфигурациями (Network Security Policy Management (NSPM)).

Данные средства представлять интерес для атакующих:

-  с точки зрения противодействия им;
-  с точки зрения получения контроля над ними.



Интеграции и экосистемы средств защиты информации





«Один в поле не воин».

пословица





Интеграции средств защиты информации между собой

-  «Вертикальные»: интеграция для передачи ИБ-данных, например, событий или оповещений от условно нижестоящих СрЗИ, коллекторов и/или программных агентов.
-  «Горизонтальные»: функциональные интеграции, например, со службой каталогов для идентификации/аутентификации пользователей домена, с NTP-сервисом для синхронизации времени, с сервисом электронной почты для рассылки оповещений и т.п.



**Экосистема (от др.-греч.
οἶκος — жилище / местопребывание
и σύστημα — целое, составленное из частей).**



The diagram illustrates the R-Vision EVO ecosystem for SOC evolution, structured into three stages of maturity and a central threat intelligence hub.

STAGE 3 TARGETED ATTACKS

- Expert Security:** Includes Internal Expertise, Intelligence, Extended Detection and Response, Assessment, and External Guidance.
- Optimum Security:** Includes Viability and response, Advanced Protection, Detection Enrichment, and People.
- Security Foundations:** Includes Endpoint, Network, Data, and Support.

STAGE 2 EVASIVE THREATS

- IT Security:** Includes IT Security.

STAGE 1 COMMODITY THREATS

- IT:** Includes IT.

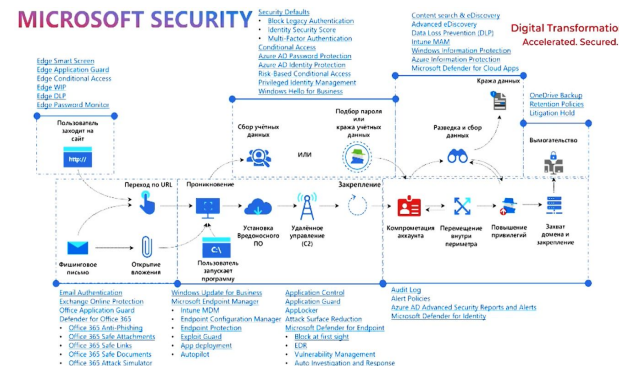
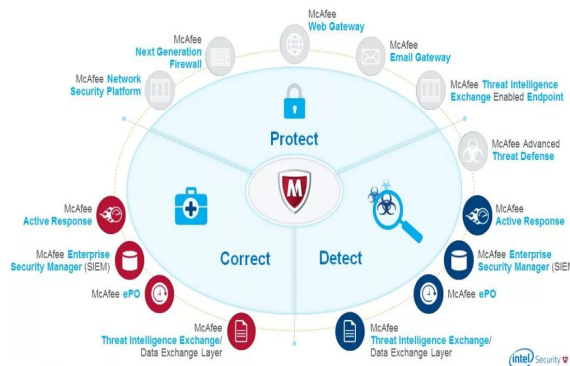
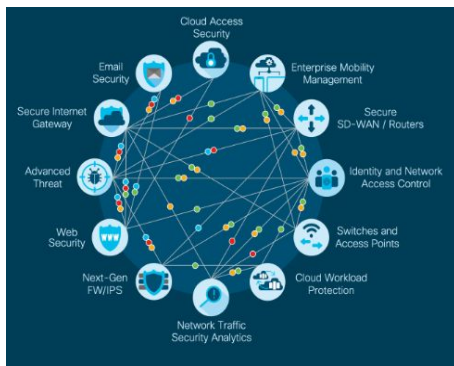
Central Hub: Knowledge Managed Detection and Response

R-Vision EVO ЭКОСИСТЕМА ТЕХНОЛОГИЙ ДЛЯ ЭВОЛЮЦИИ SOC

Threat Intelligence

- Log Management
- User and Entity Behavior Analytics
- Security Orchestration, Automation, Response
- Endpoint Security
- Vulnerability Management
- Security Asset Management
- Governance, Risk management, Compliance
- Deception

Diagram Description: The diagram shows a hierarchical structure of SOC components. At the top is the 'Главный центр ГосСОПКА' (Main Center GosSOPKA) with 'Ведомство (организация)' (Agency/organization), 'Команда центра' (Center team), 'Managed SIEM', 'IT Ведомственный центр' (IT Agency center), and 'НАЦОП' (NACOP). Below is the 'Подчиненный центр ГосСОПКА' (Subordinate Center GosSOPKA) with 'Предприятие в структуре ведомства (организации)' (Enterprise in the structure of the agency/organization), 'Managed SIEM', 'PT Application Firewall', 'PT Application Inspector', 'PT Network Attack Discovery', 'PT MultiScanner', 'Managed SIEM', 'PT IAM', 'Информационная система — объект КИИ' (Information system — object of KII), 'Серверы и дата-центры' (Servers and data centers), 'Веб-портал' (Web portal), 'Канал передачи данных' (Data transfer channel), 'Рабочие станции' (Workstations), 'Средства защиты информации' (Information protection means), and 'АСУ ТП — объекты КИИ' (SCADA — objects of KII). The central hub is 'Knowledge Managed Detection and Response'. The right side shows the 'R-Vision EVO' ecosystem with various threat intelligence components.





Достоинства и недостатки экосистем

Достоинства:

-  «Безшовность» интеграций средств между собой (в теории 😊).
-  Единый (похожий) интерфейс.
-  Централизованные средства управления (оркестратор).

Недостатки:

-  Финансовая и технологическая зависимость от конкретного производителя.
-  Сложности с эшелонированностью.



Выводы по уроку

Существуют различные некриптографические средства (механизмы) защиты информации

«Из коробки» большинство систем (отдельных приложений) предлагают набор базовых встроенных механизмов защиты информации:

-  идентификация;
-  аутентификация;
-  авторизация;
-  регистрация (учёт) событий безопасности.

Применение любого наложенного СрЗИ требует предварительного тестирования на совместимость.

Приобретение и применение любого наложенного СрЗИ – это не только стоимость лицензий, но и аппаратное, и общесистемное обеспечение для его установки, место для резервных копий, электропитание, обслуживание и администрирование (total cost of ownership).



Вопросы?

Вопросы?



Вопросы?





Спасибо за внимание

